Phase 2 Engineering Specification: Active Cyber Forensics & Hybrid Scoring

Domain: Digital Forensics • Modules: cyber_engine.py & threat_analyzer.py • Status: Production Verified

1. Phase 2 Purpose & Tools Used

While Phase 1 evaluated lexical URL features statically, Phase 2 gathers live digital forensics over the network. Attackers can construct seemingly clean URLs by registering brand-new domains or using short-lived hosting services. Phase 2 interrogates domain registration age, certificate authority validity, routing hops, and mail servers to detect infrastructure anomalies without running untrusted JavaScript locally.

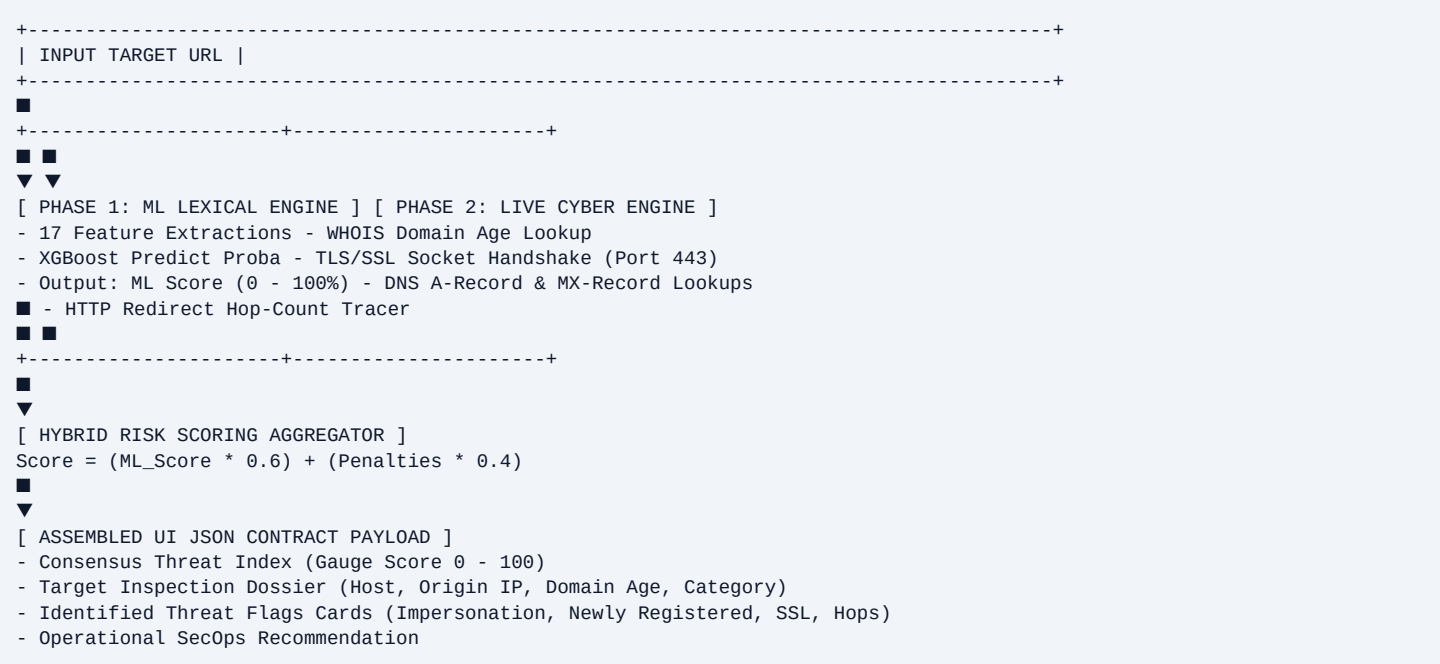
Library / Module	Function & Security Purpose	Data Extracted
python-whois	Queries global registrar registries via WHOIS protocol.	Domain creation date, age in days, registrar name.
dnspython	Direct asynchronous DNS protocol queries.	Host A-record IP resolution, Mail Exchange (MX) rec
socket & ssl	Low-level TLS/SSL handshakes over port 443.	Certificate issuer, validity status, expiration days rem
requests (Session)	Traces HTTP redirect paths safely with custom User-Agent.	Hop count, redirection trace, final target URL landing
tldextract	Accurate separation of subdomains, apex domains, and TLDs.	Standardized registered domain format for registry lo

2. Operational Workflow & Mathematical Fusion

Phase 2 fuses the machine learning output with live network indicators through a weighted scoring mechanism: **Final Risk = (ML Probability × 0.60) + (Cyber Network Penalties × 0.40)**. Network penalties are accumulated across distinct threat vectors:

Forensic Vector	Condition	Penalty Points Added	Triggered Threat Flag
WHOIS Age	Age < 7 Days	+30 Points (High Risk)	Newly Registered Domain (High Severity)
WHOIS Age	7 Days ≤ Age < 30 Days	+15 Points (Medium Risk)	Newly Registered Domain (Medium Severity)
SSL / TLS	Self-Signed, Expired, or None	+25 Points	SSL Certificate Anomaly (High Severity)
HTTP Hops	Redirect Count ≥ 2 Hops	+20 Points	Unsafe Redirect Chain (Medium Severity)
DNS Checks	No MX Records Configured	Heuristic Indicator	Missing MX Infrastructure (Low Severity)

3. Phase 2 Forensic Architecture Diagram



4. Technical Interview Questions & Answers (Phase 2)

Core Forensics, Network Telemetry, and Hybrid Risk Aggregation

---

Q1: What is the primary limitation of relying exclusively on Phase 1 lexical features?

A: Lexical analysis inspects URL string patterns only. An attacker can register a brand-new domain with a plausible, low-entropy name (e.g., cloud-verify-support.com) and host a phishing page that exhibits clean lexical features. Without live network telemetry (like detecting that the domain was registered 3 days ago), the system is vulnerable to zero-day infrastructure.

Q2: Why is domain age such a strong indicator in phishing detection?

A: Phishing campaigns use disposable infrastructure. Attackers register domains, run campaigns for hours to days, and abandon them once flagged by security scanners. Legitimate enterprise platforms maintain established domains that are years or decades old. Flagging domains under 30 days old catches the vast majority of short-lived phishing sites.

Q3: Why do we inspect DNS MX (Mail Exchange) records in a web URL scanner?

A: Authentic organizations use domains for multiple business functions, including email communication. Disposable phishing landing pages are typically set up with simple DNS A-records pointing to a web host and lack mail server infrastructure. The absence of an MX record serves as an auxiliary signal of disposable, single-use infrastructure.

Q4: How does Phase 2 inspect SSL certificates without executing untrusted web code?

A: We perform a direct socket-level TLS handshake on port 443 using Python's built-in ssl library. This inspects the X.509 certificate headers, issuer identity, and validity dates directly from the cryptographic handshake, avoiding headless browsers or executing untrusted HTML/JavaScript.

Q5: Why does the system trace HTTP redirects, and how do attackers abuse them?

A: Attackers use open redirects, URL shorteners, or multi-hop redirect chains to bypass static link crawlers and email gateways. The initial URL may look legitimate, but redirects ultimately land on a malicious site. Tracing the redirect chain allows the system to measure hop counts and evaluate the final landing domain.